Layer 3 Attacks & Defense

IE3122 – Network Security | Week 4

ICMP and IP-based attacks, and how to harden against them

Today's Agenda

- Quick overview of the ICMP protocol
- ICMP-based attacks: ICMP Sweep, Ping of Death, Ping Flood, Smurf
- IP-based (header abuse) attacks: IP Spoofing, TTL-based attacks, Teardrop
- Mitigation for each attack
- Bringing it together: layered defense at Layer 3

Learning Outcomes for Today

LO1

- Describe common network vulnerabilities and attacks — today, specifically at Layer 3.

LO2

- Evaluate different mitigation techniques for vulnerabilities and make recommendations.

- *By the end of this session you should be able to explain how each attack abuses ICMP or the IP header, and recommend a specific hardening measure for each.*

ICMP: A Quick Overview

The protocol behind ping, traceroute — and several attacks

What ICMP Is For

- Internet Control Message Protocol (ICMP) is IP's built-in diagnostic and error-reporting mechanism — it doesn't carry application data, it carries information about the network itself.
- Recall Week 1: ping uses ICMP Echo Request/Reply; traceroute uses ICMP alongside manipulated TTL values.
- Routers and hosts generate ICMP messages automatically in response to conditions like an unreachable destination, a packet that's expired, or a message too large to forward.
- Like ARP and DHCP, ICMP has no authentication — anything on the network can send it, and hosts are designed to trust and respond to it by default.

Common ICMP Message Types

Type	Purpose
Echo Request / Echo Reply	Used by ping to test reachability
Destination Unreachable	Sent when a packet can't be delivered (host, network, port, or protocol unreachable)
Time Exceeded	Sent when a packet's TTL reaches zero before arriving — what traceroute relies on
Redirect	A router telling a host a better route exists for a given destination

Why ICMP Is an Attractive Target

- Hosts are designed to respond to ICMP automatically — that automatic, trusting response is exactly what several attacks exploit.
- ICMP messages are small and cheap to generate, making them ideal for both reconnaissance (many quick probes) and volume-based denial of service.
- Because ICMP operates below the application layer, many of these attacks succeed without ever touching a vulnerable application — the network stack itself is the target.

ICMP-Based Attacks

ICMP Sweep, Ping of Death, Ping Flood, Smurf

ICMP Sweep: Overview, Vulnerability & Technique

- Overview: a reconnaissance technique — the attacker sends ICMP Echo Requests to every address in a target IP range to discover which hosts are actually alive, before attempting anything else.
- Vulnerability exploited: hosts reply to ICMP Echo Requests by default, with no authentication or rate limiting, happily confirming their own existence to anyone who asks.
- Attack technique: automated tools (e.g. nmap's ping sweep) send Echo Requests across an entire subnet in seconds; every host that replies is added to a target list for further, more specific attacks.
- This is exactly the reconnaissance phase previewed back in Week 2 — access & reconnaissance attacks are usually step one, not the whole attack.

ICMP Sweep: Mitigation

- Block or rate-limit inbound ICMP Echo Requests at the network perimeter, especially from untrusted external sources — most organisations don't need to be pingable from the public Internet at all.
- Where ICMP is needed for legitimate diagnostics, restrict it to specific trusted source addresses rather than allowing it from anywhere.
- Detective control: a burst of ICMP Echo Requests hitting a large sequential range of internal addresses in a short time is a strong signal for an IDS to flag as reconnaissance.

Ping of Death: Overview, Vulnerability & Technique

- Overview: an attack that sends a malformed, oversized ICMP packet designed to crash or destabilise the target when it's reassembled.
- Vulnerability exploited: the maximum legal IP packet size is 65,535 bytes — older or poorly written network stacks didn't properly handle a packet that arrived, via fragmentation, appearing to exceed that limit.
- Attack technique: the attacker sends a ping whose fragments, when reassembled by the target, produce a packet larger than the maximum allowed size, overflowing the reassembly buffer.
- Impact: historically caused crashes, freezes, or reboots on vulnerable systems — largely a legacy attack against modern patched operating systems, but still relevant on unpatched embedded or IoT devices.

Ping of Death: Mitigation

- Keep operating systems and network device firmware patched — this exact vulnerability was fixed industry-wide decades ago, so patching alone eliminates the risk on modern systems.
- Configure firewalls to enforce maximum packet size limits and drop malformed or illegally fragmented ICMP packets before they reach internal hosts.
- A reminder that legacy attacks don't disappear — they just move to whatever's still unpatched, which is often IoT and embedded devices with long deployment lifespans.

Ping Flood: Overview, Vulnerability & Technique

- Overview: the simplest possible ICMP attack — overwhelm the target with a high volume of Echo Requests, exhausting its bandwidth or processing capacity.
- Vulnerability exploited: a host must process every ICMP Echo Request it receives and generate a reply — there's no built-in limit on how many it can be sent per second.
- Attack technique: the attacker (or a botnet, recall Week 2's Mirai example) sends a continuous, high-rate stream of Echo Requests directly at the target.
- Impact: legitimate traffic is crowded out by the flood — a straightforward Denial of Service on Availability, one of the three CIA properties.

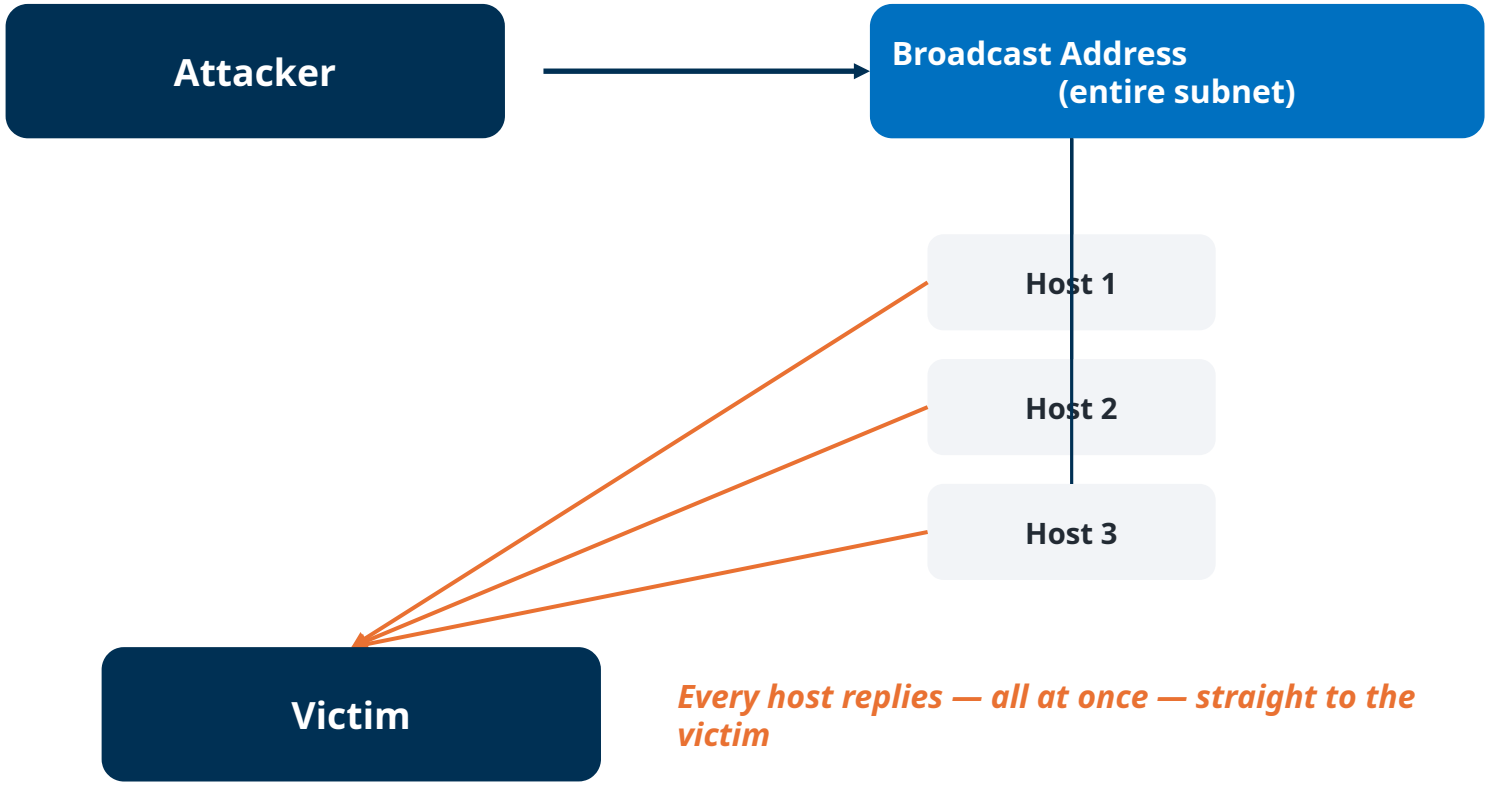
Ping Flood: Mitigation

- Rate-limit ICMP traffic at the perimeter firewall/router — cap how many ICMP packets per second are allowed from a single source.
- Use IPS/IDS to detect abnormal spikes in ICMP volume and trigger automatic blocking.
- For large-scale floods, a dedicated DDoS-protection service (recall Week 2's GitHub example) absorbs volume that on-premises equipment simply can't handle alone.

Smurf Attack: Overview & Vulnerability

- Overview: an amplification attack — the attacker gets an entire network of innocent hosts to unknowingly flood the real victim on their behalf.
- Vulnerability exploited: two things combine here — IP allows a source address to be spoofed, and many networks historically allowed ICMP Echo Requests sent to a broadcast address to be answered by every host on that network.
- This combination turns a single small request into a massive multiplied response — exactly the kind of amplification that makes volumetric DoS attacks so dangerous.

Smurf Attack: The Technique



Spoofed ICMP Echo Request: source = victim's IP

One spoofed request

→ many hosts reply

→ victim is flooded with replies it never asked for

Every host replies — all at once — straight to the victim

Smurf Attack: Mitigation

- Disable directed broadcast forwarding on routers (no ip directed-broadcast) — this single setting is why Smurf attacks are largely historical on modern, correctly configured networks.
- Ingress/egress filtering (BCP 38) at network boundaries drops packets with obviously spoofed source addresses before they can be used in an amplification attack at all.
- Rate-limit ICMP responses at the network edge as a defence-in-depth backstop, even if broadcast forwarding is already disabled.

IP-Based Attacks

Abusing the IP header itself — IP Spoofing, TTL, and fragmentation

Why the IP Header Can Be Abused

- Recall Week 1: the IP header carries the source and destination address, TTL, and fragmentation control fields — all of it set by the sender, with nothing on the wire to verify any of it is honest.
- Routers and hosts largely trust what the header claims and act on it — forward toward the claimed destination, decrement the claimed TTL, reassemble according to the claimed fragmentation flags.
- Every attack in this section works by crafting header values that are technically valid but deliberately misleading.

IP Spoofing: Overview, Vulnerability & Technique

- Overview: the attacker sends packets with a forged source IP address — one that isn't actually theirs.
- Vulnerability exploited: IP has no built-in mechanism to verify that a packet's claimed source address is genuine — routers forward based on destination only.
- Attack technique: simply set the source address field to whatever the attacker wants — a trusted internal address (to bypass source-based access controls), or a victim's address (to redirect responses toward them, as in the Smurf attack).
- Impact: enables amplification attacks, bypasses naive IP-based trust/filtering, and makes attributing an attack back to its real source significantly harder.

IP Spoofing: Mitigation

- Ingress filtering: block inbound traffic on an external interface that claims to come from your own internal address ranges — no legitimate packet would ever arrive that way.
- Egress filtering: block outbound traffic that doesn't carry a source address from your own assigned range — stops your own network being used to spoof addresses in an attack on someone else (BCP 38, the same principle behind Smurf mitigation).
- Unicast Reverse Path Forwarding (uRPF) on routers: verify that a packet's source address is reachable via the interface it arrived on, dropping it if the path doesn't make sense.

TTL-Based Attacks: A Quick Recap of TTL

- Recall Week 1: Time To Live (TTL) limits how many router hops a packet can traverse — each router decrements it by one, and a router that decrements it to zero discards the packet and returns an ICMP Time Exceeded message.
- TTL was designed to prevent packets looping forever due to routing errors — but its predictable, inspectable behaviour also makes it something attackers can exploit deliberately.
- Two distinct attacks abuse this: one targets network devices directly, the other targets the security tools meant to inspect the traffic.

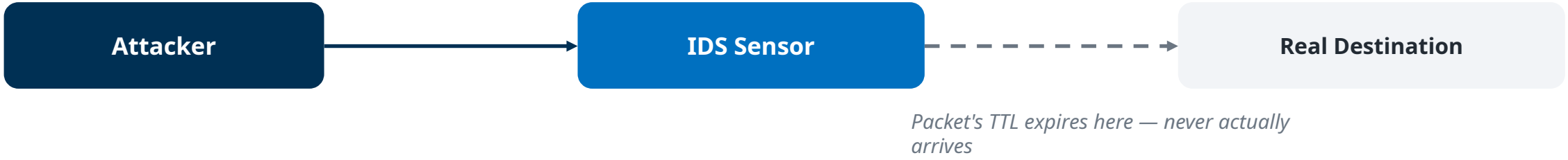
TTL Expiry Attack: Overview, Vulnerability & Technique

- Overview: the attacker deliberately sends packets with very low TTL values so that they expire at a router, forcing that router to generate an ICMP Time Exceeded reply.
- Vulnerability exploited: generating an ICMP error message costs the router CPU cycles — something it must do for every expiring packet, with no default limit on how often.
- Attack technique: flood a router with a high volume of deliberately low-TTL packets; each one forces a fresh Time Exceeded message, consuming processing capacity that should be spent forwarding real traffic.
- Impact: a denial of service aimed specifically at network infrastructure (routers) rather than end hosts — a variation on the same theme as the STP DoS attack from earlier this week.

TTL-Based Evasion Attack: Overview, Vulnerability & Technique

- Overview: an attacker crafts a TTL value so that a packet is seen differently by a security device (like an IDS) than by the actual destination host — designed to sneak malicious traffic past inspection.
- Vulnerability exploited: an IDS sitting between the attacker and the target is at a different number of hops from the target than the attacker's packet accounts for — if the TTL is tuned precisely, the packet can expire right after the IDS sees it but the IDS doesn't realise it never reached the real destination (or vice versa).
- Attack technique: the attacker sends a sequence where some packets are crafted to be processed by the IDS but silently dropped before reaching the host, while the packets the host actually assembles differ from what the IDS believes it inspected — letting disguised malicious content through undetected.
- Impact: this is a foundational IDS/IPS evasion technique — not a direct attack on availability, but a way to defeat detection entirely so a different attack can proceed unnoticed.

TTL Evasion: Why It Works



- The IDS inspects the packet and, seeing nothing wrong, allows it through — but the packet's TTL was crafted to expire in the network segment between the IDS and the real destination.
- The destination host never actually receives that packet at all — yet the IDS's picture of the conversation now doesn't match what the destination actually experiences.
- Attackers exploit this mismatch (in either direction) to slip malicious payloads past inspection while keeping the IDS's logs looking clean.

TTL-Based Attacks: Mitigation

- Rate-limit ICMP Time Exceeded generation on routers to blunt TTL expiry-based CPU exhaustion, the same principle used against Ping Flood.
- For evasion: deploy IDS/IPS sensors as close to the protected host as possible (minimising the hop-count gap an attacker could exploit), and use IDS technology that actively tracks and normalises TTL rather than passively trusting it.
- Keep IDS/IPS signature and inspection engines updated — TTL evasion is a known, well-documented technique, and modern IDS platforms include specific countermeasures for it.

Teardrop Attack (Fragmentation): Overview, Vulnerability & Technique

- Overview: an attack that sends deliberately malformed, overlapping IP fragments designed to break the reassembly process on the target.
- Vulnerability exploited: when a large packet is fragmented, each fragment carries an offset telling the receiver where it belongs during reassembly — older or poorly written IP stacks didn't properly validate that these offsets made sense.
- Attack technique: the attacker crafts fragments with overlapping, contradictory offsets. When the target tries to reassemble them, the reassembly logic can crash, hang, or corrupt memory.
- Impact: like Ping of Death, this is largely a legacy attack against modern patched systems — but the same fragmentation-based logic still appears in evasion techniques against firewalls and IDS today.

Teardrop Attack: Mitigation

- Keep operating systems patched — modern IP stacks correctly validate fragment offsets and simply discard malformed fragments instead of crashing.
- Configure firewalls to perform fragment reassembly and validation before packets reach internal hosts, dropping anything with impossible or overlapping offsets.
- Where policy allows, block fragmented traffic entirely at the perimeter for services that never legitimately need it — removes the attack surface outright.

Bringing It Together

Comparing mitigations across all eight attacks

SUMMARY

Full Mitigation Comparison

Attack	Primary mitigation
ICMP Sweep	Block/rate-limit inbound ICMP Echo at the perimeter
Ping of Death	Patching; firewall packet-size/fragment validation
Ping Flood	ICMP rate limiting; IPS detection; DDoS protection service
Smurf Attack	Disable directed broadcast; ingress/egress filtering (BCP 38)
IP Spoofing	Ingress/egress filtering; uRPF
TTL Expiry Attack	Rate-limit ICMP Time Exceeded generation on routers
TTL-Based Evasion	IDS placement close to the host; TTL-aware inspection
Teardrop (Fragmentation)	Patching; firewall fragment reassembly/validation

SUMMARY

Layered Defense at Layer 3

- Notice the repeating themes: ingress/egress filtering stops multiple attacks at once (Spoofing, Smurf) — exactly the control-minimisation principle from Week 2's layered security plan.
- Patching alone neutralises several legacy attacks (Ping of Death, Teardrop) — a reminder that not every mitigation needs to be a piece of dedicated security hardware.
- No single control here covers everything: filtering doesn't stop a flood, rate limiting doesn't stop evasion — the same layered-defense principle from Week 2 applies just as much at Layer 3 as it did at Layer 2.

Summary

- ICMP is a trusted, unauthenticated diagnostic protocol — exactly what makes ICMP Sweep, Ping of Death, Ping Flood, and Smurf all possible.
- The IP header itself — source address, TTL, fragmentation fields — is entirely sender-controlled and largely trusted, enabling IP Spoofing, TTL-based attacks, and Teardrop.
- Smurf and IP Spoofing share a common root cause (an unverifiable source address) and a common family of fixes (ingress/egress filtering).
- Legacy attacks like Ping of Death and Teardrop are mostly solved by patching — but their underlying techniques (fragmentation abuse, malformed packets) still show up in modern evasion methods.
- Layered defense applies at every layer we've studied so far — Layer 2 in Weeks 3–4, and now Layer 3 today.

This Week's Lab & Tutorial

- Lab (runs in the Week 5 session): builds on this week's 3-tier STP topology, adding STP hardening plus Layer 3 defensive configuration.
- Tutorial worksheet: study-notes-style questions covering ICMP fundamentals, both attack categories, and their mitigations — use it to prep for the mid-semester test.

References

- Santos & Stuppi, CCNA Security 210-260 Official Cert Guide, 1st Ed., Cisco Press.
- Kaufman, Perlman, Speciner & Perlner, Network Security: Private Communication in a Public World, 3rd Ed., Prentice Hall.
- Cisco Networking Academy — CCNA Security curriculum (Network Layer attacks and mitigation chapters).